



VulnSight

CONTAINER SECURITY REPORT

php:7.4-apache

sha256:c9d7e608f7383...e0ca6d

VULNSIGHT RISK SCORE

71.25

CRITICAL

SCANNED 2026-05-18 at 03:07:30 UTC

479 unique CVEs · 195 packages

Built by Venkata Sai Nataraja Vamsi Krishna Palaparty

Executive summary

This container presents a critical security posture with an overall risk score of **71.2/100**. Gype identified 1432 total vulnerability matches across 479 unique CVEs. 3 CVEs are actively exploited in the wild per the CISA KEV catalogue (**CVE-2024-38475** , **CVE-2023-44487** , **CVE-2023-4911**) and require immediate attention. Of the 479 unique CVEs, 218 (45%) have upstream fixes available and can be resolved by upgrading 68 packages. The highest-priority packages to upgrade are: apache2 (42 CVEs -> 2.4.67-1~deb11u1), apache2-bin (42 CVEs -> 2.4.67-1~deb11u1), apache2-data (42 CVEs -> 2.4.67-1~deb11u1). Additional container-level risk factors include: runs as root; exposes interactive shells (bash, curl, sh).

Risk methodology

The **VulnSight Risk Score** aggregates the top 100 highest-risk CVEs into a normalized 0–100 score. Each CVE's contribution combines six factors:

- **CVSS base score** - baseline severity rating from NVD
- **EPSS** - predicted probability of exploitation within the next 30 days
- **KEV status** - flagged in the CISA Known Exploited Vulnerabilities catalog
- **Age** - older unpatched CVEs accrue additional risk over time
- **Severity tier** - Critical, High, Medium, or Low classification
- **CWE category** - weakness type, weighted by exploitability and impact
- **Fix availability** - CVEs with a published fix carry additional weight, since they represent actionable, prioritized work for the team

Container context further adjusts the score: running as root, an end-of-life base image, SUID binaries, and exposed dangerous tools each raise the final number. Risk tiers are: **0–19 Low**, **20–39 Medium**, **40–69 High**, **70+ Critical**.

Risk overview

UNIQUE CVES

479

HIGH SEVERITY

110

MAX CVSS

9.8

AVG CVSS

6.43

KEV LISTED

3

FIXABLE

218 / 479

Severity breakdown

Critical

(65)

High

(290)

Medium

(289)

Low

(38)

Negligible

(750)

Top 5 CVEs by VulnSight Risk Score

CVE-2024-38475

48.0

CVE-2023-44487

45.4

CVE-2023-4911

43.5

CVE-2023-25690

26.1

CVE-2024-1874

25.2

Container context	
Runs as root	Yes
Base image EOL	Supported
SUID binaries	0
Dangerous tools	bash, curl, sh

3 / 12

Top 20 CVEs by VulnSight Risk Score

Showing the 20 highest-contributing CVEs out of 479 total. Complete CVE list available in the HTML report.

CVE ID	CVSS	VULNSIGHT RISK	SEVERITY	FIX
CVE-2024-38475	9.1	48.0	CRITICAL	Yes
Improper escaping of output in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows an attacker to map URLs to filesystem locations that are permitted to be served by the server but are not intentionally/directly reachable by any URL, resulting in code execution or source code disclosure. Substitutions in server context that use a backreferences or variables as the first segment of the substitution are affected. Some unsafe RewriteRules will be broken by this change and the rewrite flag "UnsafePrefixStat" can be used to opt back in once ensuring the substitution is appropriately constrained.				
CVE-2023-44487	7.5	45.4	HIGH	Yes
The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.				
CVE-2023-4911	7.8	43.5	HIGH	Yes
A buffer overflow was discovered in the GNU C Library's dynamic loader ld.so while processing the GLIBC_TUNABLES environment variable. This issue could allow a local attacker to use maliciously crafted GLIBC_TUNABLES environment variables when launching binaries with SUID permission to execute code with elevated privileges.				
CVE-2023-25690	9.8	26.1	CRITICAL	Yes
Some mod_proxy configurations on Apache HTTP Server versions 2.4.0 through 2.4.55 allow a HTTP Request Smuggling attack. Configurations are affected when mod_proxy is enabled along with some form of RewriteRule or ProxyPassMatch in which a non-specific pattern matches some portion of the user-supplied request-target (URL) data and is then re-inserted into the proxied request-target using variable substitution. For example, something like: RewriteEngine on RewriteRule "^/here/(.*)" "http://example.com:8080/elsewhere?\${1}"; [P] ProxyPassReverse /here/ http://example.com:8080/ Request splitting/smuggling could result in bypass of access controls in the proxy server, proxying unintended URLs to existing origin servers, and cache poisoning. Users are recommended to update to at least version 2.4.56 of Apache HTTP Server.				
CVE-2024-1874	9.4	25.2	CRITICAL	Yes
In PHP versions 8.1.* before 8.1.28, 8.2.* before 8.2.18, 8.3.* before 8.3.5, when using proc_open() command with array syntax, due to insufficient escaping, if the arguments of the executed command are controlled by a malicious user, the user can supply arguments that would execute arbitrary commands in Windows shell.				
CVE-2024-27316	7.5	24.9	HIGH	Yes
HTTP/2 incoming headers exceeding the limit are temporarily buffered in nghttp2 in order to generate an informative HTTP 413 response. If a client does not stop sending headers, this leads to memory exhaustion.				
CVE-2023-0286	7.4	24.7	HIGH	Yes
There is a type confusion vulnerability relating to X.400 address processing inside an X.509 GeneralName. X.400 addresses were parsed as an ASN1_STRING but the public structure definition for GENERAL_NAME incorrectly specified the type of the x400Address field as ASN1_TYPE. This field is subsequently interpreted by the OpenSSL function GENERAL_NAME_cmp as an ASN1_TYPE rather than an ASN1_STRING. When CRL checking is enabled (i.e. the application sets the X509_V_FLAG_CRL_CHECK flag), this vulnerability may allow an attacker to pass arbitrary pointers to a memcmp call, enabling them to read memory contents or enact a denial of service. In most cases, the attack requires the attacker to provide both the certificate chain and CRL, neither of which need to have a valid signature. If the attacker only controls one of these inputs, the other input must already contain an X.400 address as a CRL distribution point, which is uncommon. As such, this vulnerability is most likely to only affect applications which have implemented their own functionality for retrieving CRLs over a network.				
CVE-2023-38545	9.8	23.4	CRITICAL	Yes

CVE ID	CVSS	VULNSIGHT RISK	SEVERITY	FIX
This flaw makes curl overflow a heap based buffer in the SOCKS5 proxy handshake. When curl is asked to pass along the host name to the SOCKS5 proxy to allow that to resolve the address instead of it getting done by curl itself, the maximum length that host name can be is 255 bytes. If the host name is detected to be longer, curl switches to local name resolving and instead passes on the resolved address only. Due to this bug, the local variable that means "let the host resolve the name" could get the wrong value during a slow SOCKS5 handshake, and contrary to the intention, copy the too long host name to the target buffer instead of copying just the resolved address there. The target buffer being a heap based buffer, and the host name coming from the URL that curl has been told to operate with.				
CVE-2023-2650	6.5	23.2	MEDIUM	Yes
Issue summary: Processing some specially crafted ASN.1 object identifiers or data containing them may be very slow. Impact summary: Applications that use OBJ_obj2txt() directly, or use any of the OpenSSL subsystems OCSP, PKCS7/SMIME, CMS, CMP/CRMF or TS with no message size limit may experience notable to very long delays when processing those messages, which may lead to a Denial of Service. An OBJECT IDENTIFIER is composed of a series of numbers - sub-identifiers - most of which have no size limit. OBJ_obj2txt() may be used to translate an ASN.1 OBJECT IDENTIFIER given in DER encoding form (using the OpenSSL type ASN1_OBJECT) to its canonical numeric text form, which are the sub-identifiers of the OBJECT IDENTIFIER in decimal form, separated by periods. When one of the sub-identifiers in the OBJECT IDENTIFIER is very large (these are sizes that are seen as absurdly large, taking up tens or hundreds of KiBs), the translation to a decimal number in text may take a very long time. The time complexity is $O(n^2)$ with 'n' being the size of the sub-identifiers in bytes (*). With OpenSSL 3.0, support to fetch cryptographic algorithms using names / identifiers in string form was introduced. This includes using OBJECT IDENTIFIERS in canonical numeric text form as identifiers for fetching algorithms. Such OBJECT IDENTIFIERS may be received through the ASN.1 structure AlgorithmIdentifier, which is commonly used in multiple protocols to specify what cryptographic algorithm should be used to sign or verify, encrypt or decrypt, or digest passed data. Applications that call OBJ_obj2txt() directly with untrusted data are affected, with any version of OpenSSL. If the use is for the mere purpose of display, the severity is considered low. In OpenSSL 3.0 and newer, this affects the subsystems OCSP, PKCS7/SMIME, CMS, CMP/CRMF or TS. It also impacts anything that processes X.509 certificates, including simple things like verifying its signature. The impact on TLS is relatively low, because all versions of OpenSSL have a 100KiB limit on the peer's certificate chain. Additionally, this only impacts clients, or servers that have explicitly enabled client authentication. In OpenSSL 1.1.1 and 1.0.2, this only affects displaying diverse objects, such as X.509 certificates. This is assumed to not happen in such a way that it would cause a Denial of Service, so these versions are considered not affected by this issue in such a way that it would be cause for concern, and the severity is therefore considered low.				
CVE-2023-43622	7.5	22.3	HIGH	Yes
An attacker, opening a HTTP/2 connection with an initial window size of 0, was able to block handling of that connection indefinitely in Apache HTTP Server. This could be used to exhaust worker resources in the server, similar to the well known "slow loris" attack pattern. This has been fixed in version 2.4.58, so that such connection are terminated properly after the configured connection timeout. This issue affects Apache HTTP Server: from 2.4.55 through 2.4.57. Users are recommended to upgrade to version 2.4.58, which fixes the issue.				
CVE-2023-50387	7.5	21.2	HIGH	Yes
Certain DNSSEC aspects of the DNS protocol (in RFC 4033, 4034, 4035, 6840, and related RFCs) allow remote attackers to cause a denial of service (CPU consumption) via one or more DNSSEC responses, aka the "KeyTrap" issue. One of the concerns is that, when there is a zone with many DNSKEY and RRSIG records, the protocol specification implies that an algorithm must evaluate all combinations of DNSKEY and RRSIG records.				
CVE-2022-32221	9.8	21.0	CRITICAL	Yes
When doing HTTP(S) transfers, libcurl might erroneously use the read callback ('CURLOPT_READFUNCTION') to ask for data to send, even when the 'CURLOPT_POSTFIELDS' option has been set, if the same handle previously was used to issue a 'PUT' request which used that callback. This flaw may surprise the application and cause it to misbehave and either send off the wrong data or use memory after free or similar in the subsequent 'POST' request. The problem exists in the logic for a reused handle when it is changed from a PUT to a POST.				
CVE-2024-11236	9.8	20.8	CRITICAL	Yes
In PHP versions 8.1.* before 8.1.31, 8.2.* before 8.2.26, 8.3.* before 8.3.14, uncontrolled long string inputs to ldap_escape() function on 32-bit systems can cause an integer overflow, resulting in an out-of-bounds write.				
CVE-2024-5535	9.1	20.6	CRITICAL	Yes

CVE ID	CVSS	VULNSIGHT RISK	SEVERITY	FIX
Issue summary: Calling the OpenSSL API function <code>SSL_select_next_proto</code> with an empty supported client protocols buffer may cause a crash or memory contents to be sent to the peer. Impact summary: A buffer overread can have a range of potential consequences such as unexpected application behaviour or a crash. In particular this issue could result in up to 255 bytes of arbitrary private data from memory being sent to the peer leading to a loss of confidentiality. However, only applications that directly call the <code>SSL_select_next_proto</code> function with a 0 length list of supported client protocols are affected by this issue. This would normally never be a valid scenario and is typically not under attacker control but may occur by accident in the case of a configuration or programming error in the calling application. The OpenSSL API function <code>SSL_select_next_proto</code> is typically used by TLS applications that support ALPN (Application Layer Protocol Negotiation) or NPN (Next Protocol Negotiation). NPN is older, was never standardised and is deprecated in favour of ALPN. We believe that ALPN is significantly more widely deployed than NPN. The <code>SSL_select_next_proto</code> function accepts a list of protocols from the server and a list of protocols from the client and returns the first protocol that appears in the server list that also appears in the client list. In the case of no overlap between the two lists it returns the first item in the client list. In either case it will signal whether an overlap between the two lists was found. In the case where <code>SSL_select_next_proto</code> is called with a zero length client list it fails to notice this condition and returns the memory immediately following the client list pointer (and reports that there was no overlap in the lists). This function is typically called from a server side application callback for ALPN or a client side application callback for NPN. In the case of ALPN the list of protocols supplied by the client is guaranteed by libssl to never be zero in length. The list of server protocols comes from the application and should never normally be expected to be of zero length. In this case if the <code>SSL_select_next_proto</code> function has been called as expected (with the list supplied by the client passed in the <code>client/client_len</code> parameters), then the application will not be vulnerable to this issue. If the application has accidentally been configured with a zero length server list, and has accidentally passed that zero length server list in the <code>client/client_len</code> parameters, and has additionally failed to correctly handle a "no overlap" response (which would normally result in a handshake failure in ALPN) then it will be vulnerable to this problem. In the case of NPN, the protocol permits the client to opportunistically select a protocol when there is no overlap. OpenSSL returns the first client protocol in the no overlap case in support of this. The list of client protocols comes from the application and should never normally be expected to be of zero length. However if the <code>SSL_select_next_proto</code> function is accidentally called with a <code>client_len</code> of 0 then an invalid memory pointer will be returned instead. If the application uses this output as the opportunistic protocol then the loss of confidentiality will occur. This issue has been assessed as Low severity because applications are most likely to be vulnerable if they are using NPN instead of ALPN - but NPN is not widely used. It also requires an application configuration or programming error. Finally, this issue would not typically be under attacker control making active exploitation unlikely. The FIPS modules in 3.3, 3.2, 3.1 and 3.0 are not affected by this issue. Due to the low severity of this issue we are not issuing new releases of OpenSSL at this time. The fix will be included in the next releases when they become available.				
CVE-2024-45492	9.8	19.5	CRITICAL	Yes
An issue was discovered in libexpat before 2.6.3. <code>nextScaffoldPart</code> in <code>xmlparse.c</code> can have an integer overflow for <code>m_groupSize</code> on 32-bit platforms (where <code>UINT_MAX</code> equals <code>SIZE_MAX</code>).				
CVE-2024-45491	9.8	19.4	CRITICAL	Yes
An issue was discovered in libexpat before 2.6.3. <code>dtdCopy</code> in <code>xmlparse.c</code> can have an integer overflow for <code>nDefaultAtts</code> on 32-bit platforms (where <code>UINT_MAX</code> equals <code>SIZE_MAX</code>).				
CVE-2022-24963	9.8	19.3	CRITICAL	Yes
Integer Overflow or Wraparound vulnerability in <code>apr_encode</code> functions of Apache Portable Runtime (APR) allows an attacker to write beyond bounds of a buffer. This issue affects Apache Portable Runtime (APR) version 1.7.0.				
CVE-2025-49796	9.1	19.3	CRITICAL	Yes
A vulnerability was found in libxml2. Processing certain <code>sch:name</code> elements from the input XML file can trigger a memory corruption issue. This flaw allows an attacker to craft a malicious XML input file that can lead libxml to crash, resulting in a denial of service or other possible undefined behavior due to sensitive data being corrupted in memory.				
CVE-2023-27534	8.8	18.8	HIGH	Yes
A path traversal vulnerability exists in curl <8.0.0 SFTP implementation causes the tilde (~) character to be wrongly replaced when used as a prefix in the first path element, in addition to its intended use as the first element to indicate a path relative to the user's home directory. Attackers can exploit this flaw to bypass filtering or execute arbitrary code by crafting a path like <code>/~2/foo</code> while accessing a server with a specific user.				
CVE-2021-46848	9.1	18.7	CRITICAL	Yes
GNU Libtasn1 before 4.19.0 has an <code>ETYPE_OK</code> off-by-one array size check that affects <code>asn1_encode_simple_der</code>.				

CISA Known Exploited Vulnerabilities

3 CVE(s) on the CISA KEV catalog - actively exploited in the wild and require immediate attention.

CVE ID	CVSS	EPSS	CWE	FIX
CVE - 2023 - 44487	7.5	0.94399	NVD-CWE-noinfo	Yes
The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.				
CVE - 2024 - 38475	9.1	0.93858	CWE-116	Yes
Improper escaping of output in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows an attacker to map URLs to filesystem locations that are permitted to be served by the server but are not intentionally/directly reachable by any URL, resulting in code execution or source code disclosure. Substitutions in server context that use a backreferences or variables as the first segment of the substitution are affected. Some unsafe RewriteRules will be broken by this change and the rewrite flag "UnsafePrefixStat" can be used to opt back in once ensuring the substitution is appropriately constrained.				
CVE - 2023 - 4911	7.8	0.71534	CWE-122	Yes
A buffer overflow was discovered in the GNU C Library's dynamic loader ld.so while processing the GLIBC_TUNABLES environment variable. This issue could allow a local attacker to use maliciously crafted GLIBC_TUNABLES environment variables when launching binaries with SUID permission to execute code with elevated privileges.				

Threat intelligence

Top 10 by EPSS - exploitation probability

CVE ID	EPSS	CVSS	KEV	CWE	AGE
CVE-2023-44487	0.94399	7.5	Yes	NVD-CWE-noinfo	950
The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.					
CVE-2024-38475	0.93858	9.1	Yes	CWE-116	685
Improper escaping of output in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows an attacker to map URLs to filesystem locations that are permitted to be served by the server but are not intentionally/directly reachable by any URL, resulting in code execution or source code disclosure. Substitutions in server context that use a backreferences or variables as the first segment of the substitution are affected. Some unsafe RewriteRules will be broken by this change and the rewrite flag "UnsafePrefixStat" can be used to opt back in once ensuring the substitution is appropriately constrained.					
CVE-2023-2650	0.92082	6.5	No	CWE-770	1083
Issue summary: Processing some specially crafted ASN.1 object identifiers or data containing them may be very slow. Impact summary: Applications that use OBJ_obj2txt() directly, or use any of the OpenSSL subsystems OCSP, PKCS7/SMIME, CMS, CMP/CRMF or TS with no message size limit may experience notable to very long delays when processing those messages, which may lead to a Denial of Service. An OBJECT IDENTIFIER is composed of a series of numbers - sub-identifiers - most of which have no size limit. OBJ_obj2txt() may be used to translate an ASN.1 OBJECT IDENTIFIER given in DER encoding form (using the OpenSSL type ASN1_OBJECT) to its canonical numeric text form, which are the sub-identifiers of the OBJECT IDENTIFIER in decimal form, separated by periods. When one of the sub-identifiers in the OBJECT IDENTIFIER is very large (these are sizes that are seen as absurdly large, taking up tens or hundreds of KiBs), the translation to a decimal number in text may take a very long time. The time complexity is $O(n^2)$ with 'n' being the size of the sub-identifiers in bytes (*). With OpenSSL 3.0, support to fetch cryptographic algorithms using names / identifiers in string form was introduced. This includes using OBJECT IDENTIFIERS in canonical numeric text form as identifiers for fetching algorithms. Such OBJECT IDENTIFIERS may be received through the ASN.1 structure AlgorithmIdentifier, which is commonly used in multiple protocols to specify what cryptographic algorithm should be used to sign or verify, encrypt or decrypt, or digest passed data. Applications that call OBJ_obj2txt() directly with untrusted data are affected, with any version of OpenSSL. If the use is for the mere purpose of display, the severity is considered low. In OpenSSL 3.0 and newer, this affects the subsystems OCSP, PKCS7/SMIME, CMS, CMP/CRMF or TS. It also impacts anything that processes X.509 certificates, including simple things like verifying its signature. The impact on TLS is relatively low, because all versions of OpenSSL have a 100KiB limit on the peer's certificate chain. Additionally, this only impacts clients, or servers that have explicitly enabled client authentication. In OpenSSL 1.1.1 and 1.0.2, this only affects displaying diverse objects, such as X.509 certificates. This is assumed to not happen in such a way that it would cause a Denial of Service, so these versions are considered not affected by this issue in such a way that it would be cause for concern, and the severity is therefore considered low.					
CVE-2024-2961	0.91924	7.3	No	N/A	0
The iconv() function in the GNU C Library versions 2.39 and older may overflow the output buffer passed to it by up to 4 bytes when converting strings to the ISO-2022-CN-EXT character set, which may be used to crash an application or overwrite a neighbouring variable.					
CVE-2024-27316	0.89409	7.5	No	CWE-770	773
HTTP/2 incoming headers exceeding the limit are temporarily buffered in nghttp2 in order to generate an informative HTTP 413 response. If a client does not stop sending headers, this leads to memory exhaustion.					
CVE-2023-0286	0.88452	7.4	No	CWE-843	1194

CVE ID	EPSS	CVSS	KEV	CWE	AGE
There is a type confusion vulnerability relating to X.400 address processing inside an X.509 GeneralName. X.400 addresses were parsed as an ASN1_STRING but the public structure definition for GENERAL_NAME incorrectly specified the type of the x400Address field as ASN1_TYPE. This field is subsequently interpreted by the OpenSSL function GENERAL_NAME_cmp as an ASN1_TYPE rather than an ASN1_STRING. When CRL checking is enabled (i.e. the application sets the X509_V_FLAG_CRL_CHECK flag), this vulnerability may allow an attacker to pass arbitrary pointers to a memcmp call, enabling them to read memory contents or enact a denial of service. In most cases, the attack requires the attacker to provide both the certificate chain and CRL, neither of which need to have a valid signature. If the attacker only controls one of these inputs, the other input must already contain an X.400 address as a CRL distribution point, which is uncommon. As such, this vulnerability is most likely to only affect applications which have implemented their own functionality for retrieving CRLs over a network.					
CVE-2024-38473	0.88359	8.1	No	N/A	0
Encoding problem in mod_proxy in Apache HTTP Server 2.4.59 and earlier allows request URLs with incorrect encoding to be sent to backend services, potentially bypassing authentication via crafted requests. Users are recommended to upgrade to version 2.4.60, which fixes this issue.					
CVE-2023-4911	0.71534	7.8	Yes	CWE-122	957
A buffer overflow was discovered in the GNU C Library's dynamic loader ld.so while processing the GLIBC_TUNABLES environment variable. This issue could allow a local attacker to use maliciously crafted GLIBC_TUNABLES environment variables when launching binaries with SUID permission to execute code with elevated privileges.					
CVE-2023-25690	0.68183	9.8	No	CWE-444	1167
Some mod_proxy configurations on Apache HTTP Server versions 2.4.0 through 2.4.55 allow a HTTP Request Smuggling attack. Configurations are affected when mod_proxy is enabled along with some form of RewriteRule or ProxyPassMatch in which a non-specific pattern matches some portion of the user-supplied request-target (URL) data and is then re-inserted into the proxied request-target using variable substitution. For example, something like: RewriteEngine on RewriteRule "^/here/(.*)\$" "http://example.com:8080/elsewhere?\${1}"; [P] ProxyPassReverse /here/ http://example.com:8080/ Request splitting/smuggling could result in bypass of access controls in the proxy server, proxying unintended URLs to existing origin servers, and cache poisoning. Users are recommended to update to at least version 2.4.56 of Apache HTTP Server.					
CVE-2024-1874	0.63376	9.4	No	CWE-116	748
In PHP versions 8.1.* before 8.1.28, 8.2.* before 8.2.18, 8.3.* before 8.3.5, when using proc_open() command with array syntax, due to insufficient escaping, if the arguments of the executed command are controlled by a malicious user, the user can supply arguments that would execute arbitrary commands in Windows shell.					

Top 10 by CVSS - severity

CVE ID	CVSS	EPSS	KEV	CWE	AGE
CVE-2023-25690	9.8	0.68183	No	CWE-444	1167
Some mod_proxy configurations on Apache HTTP Server versions 2.4.0 through 2.4.55 allow a HTTP Request Smuggling attack. Configurations are affected when mod_proxy is enabled along with some form of RewriteRule or ProxyPassMatch in which a non-specific pattern matches some portion of the user-supplied request-target (URL) data and is then re-inserted into the proxied request-target using variable substitution. For example, something like: RewriteEngine on RewriteRule "^/here/(.*)\$" "http://example.com:8080/elsewhere?\${1}"; [P] ProxyPassReverse /here/ http://example.com:8080/ Request splitting/smuggling could result in bypass of access controls in the proxy server, proxying unintended URLs to existing origin servers, and cache poisoning. Users are recommended to update to at least version 2.4.56 of Apache HTTP Server.					
CVE-2023-38545	9.8	0.2625	No	CWE-787	942
This flaw makes curl overflow a heap based buffer in the SOCKS5 proxy handshake. When curl is asked to pass along the host name to the SOCKS5 proxy to allow that to resolve the address instead of it getting done by curl itself, the maximum length that host name can be is 255 bytes. If the host name is detected to be longer, curl switches to local name resolving and instead passes on the resolved address only. Due to this bug, the local variable that means "let the host resolve the name" could get the wrong value during a slow SOCKS5 handshake, and contrary to the intention, copy the too long host name to the target buffer instead of copying just the resolved address there. The target buffer being a heap based buffer, and the host name coming from the URL that curl has been told to operate with.					
CVE-2022-32221	9.8	0.01759	No	CWE-200	1259

CVE ID	CVSS	EPSS	KEV	CWE	AGE
When doing HTTP(S) transfers, libcurl might erroneously use the read callback ('CURLOPT_READFUNCTION') to ask for data to send, even when the 'CURLOPT_POSTFIELDS' option has been set, if the same handle previously was used to issue a 'PUT' request which used that callback. This flaw may surprise the application and cause it to misbehave and either send off the wrong data or use memory after free or similar in the subsequent 'POST' request. The problem exists in the logic for a reused handle when it is changed from a PUT to a POST.					
CVE-2024-11236	9.8	0.00443	No	CWE-787	540
In PHP versions 8.1.* before 8.1.31, 8.2.* before 8.2.26, 8.3.* before 8.3.14, uncontrolled long string inputs to ldap_escape() function on 32-bit systems can cause an integer overflow, resulting in an out-of-bounds write.					
CVE-2024-45492	9.8	0.02269	No	CWE-190	625
An issue was discovered in libexpat before 2.6.3. nextScaffoldPart in xmlparse.c can have an integer overflow for m_groupSize on 32-bit platforms (where UINT_MAX equals SIZE_MAX).					
CVE-2024-45491	9.8	0.01143	No	CWE-190	625
An issue was discovered in libexpat before 2.6.3. dtdCopy in xmlparse.c can have an integer overflow for nDefaultAtts on 32-bit platforms (where UINT_MAX equals SIZE_MAX).					
CVE-2022-24963	9.8	0.00138	No	CWE-190	1202
Integer Overflow or Wraparound vulnerability in apr_encode functions of Apache Portable Runtime (APR) allows an attacker to write beyond bounds of a buffer. This issue affects Apache Portable Runtime (APR) version 1.7.0.					
CVE-2025-6965	9.8	0.01689	No	CWE-197	306
There exists a vulnerability in SQLite versions before 3.50.2 where the number of aggregate terms could exceed the number of columns available. This could lead to a memory corruption issue. We recommend upgrading to version 3.50.2 or above.					
CVE-2022-23901	9.8	0.00258	No	CWE-787	1510
A stack overflow re2c 2.2 exists due to infinite recursion issues in src/dfa/dead_rules.cc.					
CVE-2019-1010022	9.8	0.00129	No	CWE-119	2498
GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate "this is being treated as a non-security bug and no real threat.					

Top 20 affected packages

Ranked by number of CVEs affecting each package. Complete component list (195 packages) available in the HTML report's SBOM Viewer.

PACKAGE	CVE COUNT	SUGGESTED FIX VERSION
binutils-common 2.35.2-2	92	<i>no upstream fix</i>
apache2-bin 2.4.54-1~deb11u1	50	2.4.61-1~deb11u1
curl 7.74.0-1.3+deb11u3	42	7.74.0-1.3+deb11u10
libssl1.1 1.1.1n-0+deb11u3	31	1.1.1n-0+deb11u4
libc-bin 2.31-13+deb11u5	28	2.31-13+deb11u7
libgnutls30 3.7.1-5+deb11u2	26	3.7.1-5+deb11u3
libphp 7.4.33	25	8.1.28
libxml2 2.9.10+dfsg-6.7+deb11u3	25	2.9.10+dfsg-6.7+deb11u8
libexpat1 2.2.10-2+deb11u5	18	2.2.10-2+deb11u6
libsystemd0 247.3-7+deb11u1	16	247.3-7+deb11u6
libglib2.0-0 2.66.8-1	16	2.66.8-1+deb11u7
libgssapi-krb5-2 1.18.3-6+deb11u2	11	1.18.3-6+deb11u3
libsqlite3-0 3.34.1-3	7	3.34.1-3+deb11u1
libperl5.32 5.32.1-4+deb11u2	6	5.32.1-4+deb11u4
libldap-2.4-2 2.4.57+dfsg-3+deb11u1	6	<i>no upstream fix</i>
libncurses6 6.2+20201114-2	5	6.2+20201114-2+deb11u2
libpcre3 2:8.39-13	5	<i>no upstream fix</i>
bsdutils 1:2.36.1-8+deb11u1	5	2.36.1-8+deb11u2
login 1:4.8.1-1	5	1:4.8.1-1+deb11u1
libgcrypt20 1.8.7-6	4	<i>no upstream fix</i>

Remediation plan

Upgrading 68 packages will resolve 218 fixable CVEs. 9 of those packages are linked to actively exploited vulnerabilities and should be upgraded first. Prioritise the 279 Critical and High severity CVEs with available fixes.

P1 CRITICAL	2	P2 HIGH	1	P3 MEDIUM	2	P4 LOW	1
-------------	---	---------	---	-----------	---	--------	---

P1 - Critical

- Prioritise upgrading the highest-impact packages:
 - apache2 -> upgrade to 2.4.67-1~deb11u1 (42 CVEs fixed)
 - apache2-bin -> upgrade to 2.4.67-1~deb11u1 (42 CVEs fixed)
 - apache2-data -> upgrade to 2.4.67-1~deb11u1 (42 CVEs fixed)
- 9 packages are linked to actively exploited (KEV) vulnerabilities. Upgrade these immediately to reduce real-world exploitation risk.

P2 - High

- Address the 279 Critical and High-severity CVEs with available fixes. These represent the highest likelihood of compromise.

P3 - Medium

- 68 packages have newer versions available that resolve 218 fixable CVEs. Update these packages using the package manager appropriate for your base image (e.g., apk, apt, yum, dnf, zypper, microdnf).
- Run the container as a non-root user to limit post-exploitation impact.

P4 - Low

- Remove unnecessary interactive tools (bash, curl, sh) to reduce attack surface.